

SFTP API Quickstart

API Quickstart — Account Management with curl

Revision: 1 **Last modified:** 2026-07-11T15:23:48Z

PLANNED — lands with STREAM-2 (ATM-002). This tutorial is the committed API contract walkthrough; it becomes executable when the Go/Gin API ships. Every response shown is the designed shape, validated at closure by a real curl round-trip transcript in docs/qa/ATM-002/ (§11.4.83).

Goal: obtain a super-admin token, CRUD one account end-to-end, and confirm the effect on the SFTP side — all from the shell.

Table of contents

1. [Prerequisites](#)
2. [Health check](#)
3. [Bootstrap \(first run only\)](#)
4. [Login → token](#)
5. [Create an account](#)
6. [List + inspect](#)
7. [Update \(permission + password\)](#)
8. [Verify on the SFTP side](#)
9. [Delete](#)
10. [Errors you will meet](#)

1. Prerequisites

Stack running ([quickstart.md](#) §1-§3), curl, jq, and API_PORT (default 7722). Export a base URL:

```
export API=http://127.0.0.1:7722
```

2. Health check

```
curl -fsS $API/healthz && echo          # {"status":"ok"}
curl -fsS $API/readyz && echo
      # 200 once DB + renderer are ready
```

3. Bootstrap (first run only)

Single-shot — creates the super-admin. Prefer scripts/setup.sh, which prompts without echoing; raw form:

```
curl -fsS -X POST $API/api/v1/bootstrap \
  -H 'Content-Type: application/json' \
  -d '{"username":"admin","password":"<strong-password>"}'
# → 201 {"username":"admin","role":"super_admin"}
```

A second call returns 409 Conflict — that is the correct behavior, not a bug.

4. Login → token

```
TOKEN=$(curl -fsS -X POST $API/api/v1/auth/login \
  -H 'Content-Type: application/json' \
  -d '{"username":"admin","password":"<strong-password>"}' | jq
  -r .token)
test -n "$TOKEN" && echo "token acquired"
```

Tokens are short-lived JWTs; re-run this step on 401. Never log or commit the token (§11.4.10).

5. Create an account

```
curl -fsS -X POST $API/api/v1/accounts \
  -H "Authorization: Bearer $TOKEN" \
  -H 'Content-Type: application/json' \
  -d '{
    "username": "alice",
    "password": "<strong-password>",
    "permission": "read_write",
    "public": false
  }'
# → 201 {"username":"alice","permission":"read_write","public":false,"status":"act
```

Note what the response does **not** contain: any password material. Validation rejects unknown fields, bad permission values, and public:true without public_acknowledged:true.

6. List + inspect

```
curl -fsS -H "Authorization: Bearer $TOKEN" $API/api/v1/accounts  
| jq  
curl -fsS -H "Authorization: Bearer $TOKEN" $API/api/v1/accounts/  
alice | jq
```

7. Update (permission + password)

```
# Demote to read_only  
curl -fsS -X PATCH $API/api/v1/accounts/alice \  
-H "Authorization: Bearer $TOKEN" -H 'Content-Type: application/  
json' \  
-d '{"permission":"read_only"}'  
  
# Rotate password  
curl -fsS -X PATCH $API/api/v1/accounts/alice \  
-H "Authorization: Bearer $TOKEN" -H 'Content-Type: application/  
json' \  
-d '{"password":"<new-strong-password>"}'
```

Each change re-renders `users.conf` atomically and reloads the container; new logins see it immediately, in-flight sessions are not killed.

8. Verify on the SFTP side

The API result is necessary but not sufficient — prove the SFTP behavior changed (§11.4 anti-bluff):

```
cd /tmp && echo probe > probe.txt  
  
# read_write phase: upload must succeed  
sftp -P 7721 alice@127.0.0.1 <<'EOF'  
cd upload  
put probe.txt  
bye  
EOF  
  
# after demotion to read_only: upload must be DENIED  
sftp -P 7721 alice@127.0.0.1 <<'EOF'  
cd upload  
put probe.txt probe2.txt  
bye  
EOF
```

Expected: first put reaches 100%; second returns Permission denied. The ATM-003 acceptance suite captures exactly this round-trip as its evidence.

9. Delete

```
curl -fsS -X DELETE $API/api/v1/accounts/alice \
  -H "Authorization: Bearer $TOKEN" # → 204; data/
    retained
curl -fsS -H "Authorization: Bearer $TOKEN" $API/api/v1/accounts/
  alice
# → 404 – gone from DB and users.conf
```

Add `?purge_data=true` to also remove the home directory (audit-logged; see [user_management_guide.md §10](#)).

10. Errors you will meet

Status	Meaning	Action
400	schema/validation failure (unknown field, bad enum, weak password)	fix the body; message names the field
401	missing/expired/invalid token	re-login (§4)
403	authenticated but not permitted	super-admin required
404	unknown account	check username casing
409	bootstrap already consumed / duplicate username	use login / pick another name
422	public-guard or policy rejection (public+read_write, missing acknowledgement)	see permissions_model.md
429	rate limited	back off; see security guide §6

Full field-level contract: the OpenAPI spec served by the API (`/api/v1/openapi.json`, ATM-002) — and its generated reference in the docs set.

Sources verified (2026-07-11)

- Internal: `docs/Issues.md` ATM-002/003 (endpoint contract, permission enum, public-guard, renderer + provisioner)

behavior) · docs/plans/master_implementation_plan.md · docs/
guides/user_management_guide.md.

- External: none fetched for this file specifically — SFTP-side facts verified via the guides' fetches on 2026-07-11 (atmoz/sftp users.conf + chroot semantics).